

OE-EC803C — Cyber Security

Semester VIII • 3L:0T:0P • 3 Credits

Module 1: Introduction to Cyber Security & Policy

CGEC | B.Tech ECE (2023–27) | *Biraj Sarkar*

Contents

1	Cyber Security Fundamentals & Evolution	2
1.1	Generational Evolution of Cyber Threats	2
1.2	Defense-in-Depth Architecture	2
2	Cyber Security Policy & Governance Domains	3
2.1	Strategy Versus Policy	3
2.2	Key Operational Policy Domains	3
3	Laws, Regulations & Regulatory Compliance	4
4	Technology Operations, Configuration & Productivity	4
5	E-Commerce, Counter Measures Challenges & Botnets	5
5.1	E-Commerce Counter Measures Challenges	5
5.2	Botnets & C2 Architecture	5

1. Cyber Security Fundamentals & Evolution

Cyber Security encompasses the technologies, processes, and governance policies designed to protect networks, computer devices, software applications, and critical data from unauthorized access, cyber attacks, or service disruption.

Definition: The CIA Triad & Parkerian Hexad

- **Confidentiality:** Ensuring data is accessible only to authorized entities. Enforced via AES-256 encryption, access control lists (ACLs), and TLS protocols.
- **Integrity:** Protecting data accuracy against unauthorized modification or tampering. Enforced via SHA-256 cryptographic hashes and digital signatures.
- **Availability:** Guaranteeing timely, uninterrupted system access for authorized users. Enforced via redundant hardware, load balancing, and DDoS mitigations.
- **Parkerian Hexad Extensions:** Extends CIA triad by adding *Authenticity* (verifying identity), *Utility* (usefulness of data), and *Possession/Control* (physical/logical custody).

1.1 Generational Evolution of Cyber Threats

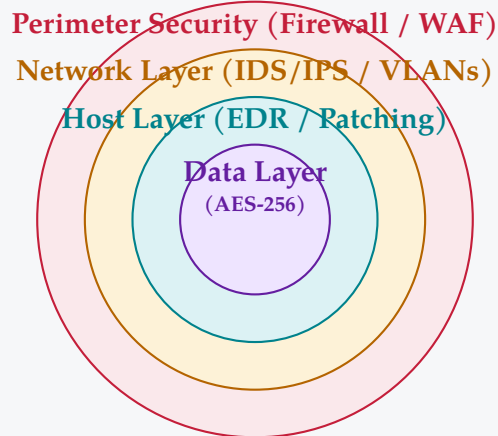
Cyber threat vectors have evolved over four distinct historical eras:

1. **First Generation (1980s–1990s):** Standalone boot-sector viruses and early worms (Brain Virus, Morris Worm) transmitted via floppy disks. Defense relied on signature-based antivirus scanning.
2. **Second Generation (2000s):** Network-propagating worms and mass-mailing malware (ILOVEYOU, Code Red, Slammer). Introduced stateful firewalls and Intrusion Detection Systems (IDS).
3. **Third Generation (2010s):** Advanced Persistent Threats (APTs), polymorphic ransomware (WannaCry, NotPetya), and distributed botnets. Introduced Next-Generation Firewalls (NGFW) and Endpoint Detection & Response (EDR).
4. **Fourth Generation (2020s–Present):** AI-driven deepfake social engineering, zero-day supply chain breaches (SolarWinds), and cloud-native infrastructure targeted attacks.

1.2 Defense-in-Depth Architecture

Defense-in-Depth enforces multiple layered security controls across the enterprise:

Defense-in-Depth Layered Model



2. Cyber Security Policy & Governance Domains

Definition: Security Policy Hierarchy

A **Security Policy** defines mandatory rules establishing governance boundaries. Governance follows a strict three-tier hierarchy:

Governance Tier	Primary Objective	Audience & Enforcement
Strategy	Defines long-term cybersecurity vision, risk posture, and 3-to-5 year strategic roadmaps.	Executive Board, CISO, CIO.
Policy	Establishes mandatory compliance rules, responsibilities, and operational boundaries.	All Employees, Contractors, System Admins.
Procedure	Standard Operating Procedures (SOPs) detailing step-by-step technical execution.	IT Operations, Security Engineers, Helpdesk.

2.1 Strategy Versus Policy

- **Cyber Strategy:** High-level direction defining risk tolerance, budget allocation, and long-term security transformation goals.
- **Enterprise Policy:** Specific, enforceable rules dictating daily behavior, access rights, and technical compliance boundaries.

2.2 Key Operational Policy Domains

- **Acceptable Use Policy (AUP):** Specifies acceptable employee behavior regarding corporate hardware, internet browsing, and email usage.
- **Access Control Policy:** Enforces Role-Based Access Control (RBAC), Multi-Factor Authentication (MFA), and the Principle of Least Privilege.

- **Data Classification Policy:** Categorizes data into Public, Internal, Confidential, and Restricted tiers to determine required encryption controls.
- **Incident Response Policy:** Outlines 6-phase incident response steps: Preparation → Identification → Containment → Eradication → Recovery → Lessons Learned.

3. Laws, Regulations & Regulatory Compliance

Cyber policy must align strictly with statutory legal frameworks:

Detailed Indian IT Act 2000 Section Breakdown

- **Section 43:** Penalty for damaging computer systems, unauthorized downloading, or introducing virus contaminants (fine up to INR 1 Crore).
- **Section 65:** Punishment for tampering with computer source documents (imprisonment up to 3 years or fine up to INR 2 Lakhs).
- **Section 66:** Hacking with computer system (dishonestly or fraudulently damaging system data).
- **Section 66B / 66C / 66D:** Punishment for receiving stolen computer resource, identity theft, and cheating by impersonation using computer resources.
- **Section 66E / 66F:** Punishment for capturing/publishing private images without consent, and **Cyber Terrorism** (denying access to critical national infrastructure with intent to threaten national unity; penalty: **Life Imprisonment**).
- **Section 79:** Intermediary liability safe-harbor guidelines requiring platforms (e.g. social media) to observe due diligence.

4. Technology Operations, Configuration & Productivity

System hardening and technology configuration reduce an asset's attack surface while balancing operational productivity:

1. **Disabling Default Credentials & Unused Ports:** Changing default administrative passwords (e.g. 'admin/admin') and closing unnecessary open ports (e.g. disabling Telnet port 23 in favor of SSH port 22).
2. **Automated Patch Management:** Deploying centralized patch management (e.g. WSUS) to test and push vendor security updates within strict SLAs.
3. **Configuration Baselineing:** Utilizing Center for Internet Security (CIS) Benchmarks to lock down OS configurations via Group Policy Objects (GPO).
4. **Productivity vs Security Tradeoff:** Overly stringent security controls (e.g. complex 30-day password changes, blocked USB ports) can hinder employee productivity, prompting workers to seek unsafe workaround solutions ("Shadow IT"). Effective security policies optimize usability alongside security.

5. E-Commerce, Counter Measures Challenges & Botnets

5.1 E-Commerce Counter Measures Challenges

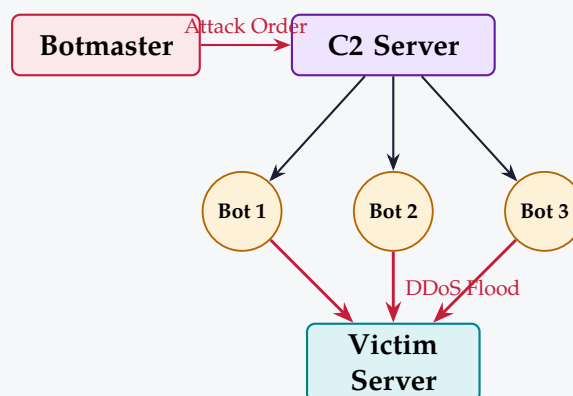
E-commerce infrastructure connects web servers, payment gateways, and backend databases, introducing unique defense challenges:

- **Dynamic Attack Vectors:** Web Application Firewall (WAF) bypasses, SQL injection, Cross-Site Scripting (XSS), and automated credential stuffing.
- **Zero-Downtime Requirement:** Countermeasures must inspect and mitigate attack traffic in real-time without latency or service downtime for legitimate customers.

5.2 Botnets & C2 Architecture

A **Botnet** is a network of compromised internet-connected devices (bots) controlled remotely by a Botmaster via a Command and Control (C2) server.

Botnet Command and Control (C2) Flow



Real-World Case Study: Mirai Botnet Attack (2016)

1. **Infection Vector:** Mirai scanned the public internet for vulnerable IoT devices (CCTV cameras, home routers) protected only by 60 factory default username/password combinations.
2. **Execution:** Infected over 600,000 IoT devices, building a massive distributed botnet without user knowledge.
3. **Impact:** Executed a record-breaking 1.2 Tbps DNS SYN flood against Dyn DNS provider, knocking offline major platforms including Twitter, Netflix, Reddit, and Spotify across the US East Coast.

Quick Revision — Module 1

Introduction to Cyber Security & Policy | OE-EC803C

Key Concepts and Metrics at a Glance

CIA Triad	Confidentiality (AES), Integrity (SHA-256), Availability (Redundancy/DDoS defense).
Section 66F IT Act	Indian cyber law prescribing Life Imprisonment for Cyber Terrorism.
Mirai Botnet	IoT botnet exploit utilizing default credentials to generate 1.2 Tbps DDoS attacks.
Defense-in-Depth	Multi-layered security (Perimeter → Network → Host → Application → Data).
AUP Policy	Acceptable Use Policy governing permissible workplace IT resource usage.

One-Line Definitions

- **System Hardening:** Disabling unnecessary services and ports to minimize vulnerability attack surface.
- **C2 Server:** Centralized command server used by botmasters to send instructions to infected bots.
- **Parkerian Hexad:** Security model expanding CIA with Authenticity, Utility, and Possession.
- **Intermediary Safe Harbor:** Legal protection for web platforms under Section 79 of Indian IT Act.

Frequently Asked / Viva Questions

Q1. Define the CIA Triad and give one technical control for each pillar.

Confidentiality (AES-256 encryption), Integrity (SHA-256 hashing), Availability (load balancing and DDoS mitigations).

Q2. Differentiate between a Security Policy, Strategy, and Procedure.

Strategy is executive vision; Policy is mandatory compliance rules; Procedure is step-by-step technical execution instructions.

Q3. What penalty does Section 66F of the Indian IT Act 2000 impose?

Life imprisonment for committing Cyber Terrorism against critical national infrastructure.

Q4. Explain the architecture of a Botnet Command and Control (C2) server.

The botmaster issues commands to the centralized C2 server, which relays orders to thousands of infected zombie bots to execute attacks.

Frequently Asked / Viva Questions (contd.)**Q5. What is System Hardening and why is it important?**

The process of locking down OS configurations, disabling unused ports/services, and applying security patches to minimize attack surface.

Q6. Describe the Mirai Botnet case study of 2016.

Mirai compromised 600,000+ IoT devices using factory default passwords, generating a 1.2 Tbps DDoS attack that knocked Dyn DNS offline.

Q7. What is an Acceptable Use Policy (AUP)?

A mandatory document defining acceptable and prohibited employee activities on corporate networks, laptops, and internet channels.

Q8. Explain the Defense-in-Depth security model.

Deploying multiple redundant security layers (firewall, network IDS, host EDR, data encryption) so if one layer fails, subsequent layers block the attack.

Q9. What is Section 43 of the Indian IT Act?

Imposes civil liability and damages up to INR 1 Crore for unauthorized system access, downloading data, or inserting malware.

Q10. What are the 6 phases of Incident Response?

Preparation → Identification → Containment → Eradication → Recovery → Lessons Learned.

Q11. Explain the Parkerian Hexad framework.

An expanded security framework adding Authenticity, Utility, and Possession/Control to the traditional CIA triad.

Q12. Why is attribution difficult in cyber crime investigations?

Attackers route malicious traffic through encrypted Tor nodes, VPN proxies, and spoofed IP headers across multi-national jurisdictions.

Q13. What is the Principle of Least Privilege?

Granting users and service accounts only the minimum access rights needed to perform their assigned work tasks.

Q14. Explain the threat of Fourth-Generation cyber attacks.

AI-driven deepfake phishing, automated zero-day exploit discovery, and targeted supply chain software breaches.

Q15. What is Section 79 of the Indian IT Act?

Provides safe-harbor immunity to network intermediaries (ISPs, social media platforms) if they observe government due diligence.

Summary Comparison: Cyber Security Governance Tiers

Governance Tier	Mandatory Level	Focus Area	Revision Cycle
Strategy	Visionary	Business Alignment	3 to 5 Years
Policy	Mandatory	Governance Rules	Annual Review
Procedure	Mandatory	Technical Steps	Continuous / Quarterly
Guideline	Optional	Best Practice Advice	As Needed